

# 3000-iqxivav6b63ryvbciag44g-50ce8d6f.us2.manus.computer

Verified review completed 2026-08-20T11:05:27.910Z. This PDF contains bounded, evidence-based findings only.

|               |       |           |        |
|---------------|-------|-----------|--------|
| POSTURE SCORE | GRADE | ATTENTION | AGENTS |
| 20/100        | E     | 17        | 15/15  |

**Scope note.** This is a bounded defensive posture review for <https://3000-iqxivav6b63ryvbciag44g-50ce8d6f.us2.manus.computer/>. It does not prove the absence of vulnerabilities and does not contain raw cookie values, owner-evidence contents, or private credentials.

## Owner evidence

5 redacted owner file(s) were reviewed for this report only. Evidence contents are never included in this PDF.

## Coverage

- Verified public response
- Transport and response headers
- Visible cookie attributes
- Sampled HTML asset references
- Public technology hints
- 5 redacted owner-evidence file(s), processed for this review only

## Limitations

- No credentialed testing or authentication bypass attempts
- No active exploitation, fuzzing, brute force, or denial-of-service testing
- Source review is limited to the selected redacted excerpts supplied by the owner

## How to read the detailed report

Every agent appears in the following pages. A completed agent without an attention item is not proof that its area is vulnerability-free; it simply did not receive a concrete signal in the reviewed material.

# Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 01

COMPLETE  
1 attention

Transport agent

Evidence scope: HTTPS, redirects, HSTS and secure response delivery

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

HSTS policy

Observed signal: strict-transport-security was not present in the verified response.

| Why it matters                                                                    | Required change                                                                          | Acceptance check                                                                                                                          |
|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Without HSTS, returning visitors may be more exposed to protocol-downgrade risks. | Set a reviewed Strict-Transport-Security policy once all subdomains are ready for HTTPS. | Request a representative protected route and confirm the strict-transport-security response header is present with an appropriate policy. |

OWASP ASVS v5.0.0 — Communications Security

Observed controls and limited review notes (1)

- HTTPS transport observed: Verified target responded over HTTPS.

Browser isolation agent

Evidence scope: CSP, framing, MIME and browser permissions

3 concrete evidence-backed attention findings require remediation.

MEDIUM

high confidence · attention

Content Security Policy

Observed signal: content-security-policy was not present in the verified response.

Why it matters

Required change

Acceptance check

A missing CSP removes an important browser-side containment layer against script injection impacts.

Implement a restrictive, tested Content-Security-Policy and progressively remove broad script allowances.

Request a representative protected route and confirm the content-security-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – Encoding and Sanitization

LOW

high confidence · attention

MIME sniffing protection

Observed signal: x-content-type-options was not present in the verified response.

Why it matters

Required change

Acceptance check

Without an explicit no-sniff directive, browsers may infer unexpected content types in edge cases.

Set X-Content-Type-Options: nosniff for relevant responses and validate declared MIME types.

Request a representative protected route and confirm the x-content-type-options response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – File Handling

LOW

high confidence · attention

## Permissions policy

**Observed signal:** permissions-policy was not present in the verified response.

Why it matters

Browser features may be available more broadly than the application needs.

Required change

Define a Permissions-Policy that disables browser features not required by the product.

Acceptance check

Request a representative protected route and confirm the permissions-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – Secure Coding

AGENT 03

COMPLETE  
1 attention

## Session agent

**Evidence scope:** Visible cookies and session posture

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

medium confidence · attention

## Observed cookie hardening is incomplete

**Observed signal:** 1 Set-Cookie response value(s) were observed in the verified response; values are intentionally not retained in the report.

Why it matters

Session or state cookies without appropriate browser attributes may have weaker protection against common client-side threats.

Required change

Review each session and sensitive-state cookie; apply Secure, HttpOnly, and an appropriate SameSite setting where compatible with the authentication flow.

Acceptance check

Inspect cookies emitted by sign-in, recovery, and sensitive state transitions without exposing their values in logs.

OWASP ASVS v5.0.0 – Authentication and Session Management

# Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 04

COMPLETE  
1 attention

Authentication agent

Evidence scope: Owner-provided authentication evidence

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

JWT signing value is embedded in source

Observed signal: Redacted owner evidence contains a JWT signing call with a literal value. No source excerpt is retained in the report.

| Why it matters                                                                          | Required change                                                                                                                                  | Acceptance check                                                                                                                                |
|-----------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| A signing value embedded in source can be copied into builds or source-control history. | Read the JWT signing value from a server-only secret at startup; reject startup when it is missing and rotate the existing value before release. | Add a startup test that fails without the secret and an integration test that accepts tokens signed with the configured replacement value only. |

OWASP ASVS v5.0.0 — Authentication

AGENT 05

COMPLETE  
1 attention

Authorization agent

Evidence scope: Owner-provided role, tenant and ownership evidence

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

Client-supplied privilege value accepted

**Observed signal:** Redacted owner evidence assigns a role or privilege value directly from a request body. No source excerpt is retained in the report.

Why it matters

A client-controlled privilege field can allow privilege escalation if it is trusted at a protected action.

Required change

Ignore client-supplied privilege fields for protected actions; derive roles server-side and enforce ownership or tenant checks before the state change.

Acceptance check

Add tests that submit elevated role fields from an unprivileged client and confirm the protected action is denied.

OWASP ASVS v5.0.0 — Authorization

AGENT 06

COMPLETE  
1 attention

Input safety agent

Evidence scope: Validation, encoding and unsafe-rendering cues

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

Unsafe dynamic rendering or execution API used

**Observed signal:** Redacted owner evidence uses a dynamic execution or HTML-rendering API. No source excerpt is retained in the report.

Why it matters

Dynamic execution or unsanitized HTML rendering can turn untrusted input into script execution.

Required change

Remove the unsafe API where possible; otherwise sanitize untrusted HTML with a maintained sanitizer and keep scripts, event attributes, and dangerous URL schemes disallowed.

Acceptance check

Add rendering tests with script tags, event attributes, and javascript: URLs and confirm none execute or render as active content.

OWASP ASVS v5.0.0 — Encoding and Sanitization

# Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 07

COMPLETE  
1 attention

Client exposure agent

Evidence scope: Client delivery, metadata and HTTP-resource cues

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

medium confidence · attention

Potential HTTP resource reference

Observed signal: The sampled HTML contains at least one http:// resource reference.

| Why it matters                                                                      | Required change                                                                                                     | Acceptance check                                                               |
|-------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Insecure subresource references can weaken a secure page or be blocked by browsers. | Replace HTTP resource references with HTTPS sources and add reporting or enforcement through CSP where appropriate. | Review production pages in browser developer tools for mixed-content warnings. |

OWASP ASVS v5.0.0 — Communications Security

Observed controls and limited review notes (1)

- Technology disclosure: No Server or X-Powered-By response hint was observed.



API & error agent

Evidence scope: Route and error-handling evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

### Stack trace returned to a client

**Observed signal:** Redacted owner evidence sends an error stack in a response payload. No source excerpt is retained in the report.

| Why it matters                                                                             | Required change                                                                                                                                | Acceptance check                                                                                   |
|--------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Stack traces can disclose internal paths, packages, and implementation details to clients. | Replace stack-trace responses with a stable error code and generic message; log diagnostic detail only through the server-side logging policy. | Add an error-path test that confirms client responses exclude stack, path, and dependency details. |

OWASP WSTG — Error Handling

AGENT 09

COMPLETE  
1 attention

Data privacy agent

Evidence scope: Referrer and sensitive-data handling cues

1 concrete evidence-backed attention finding requires remediation.

LOW

high confidence · attention

Referrer policy

Observed signal: referrer-policy was not present in the verified response.

Why it matters

Sensitive paths or query parameters can be disclosed to destinations through browser referrer behavior.

Required change

Set a reviewed Referrer-Policy such as strict-origin-when-cross-origin, subject to product requirements.

Acceptance check

Request a representative protected route and confirm the referrer-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – Data Protection

# Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 10

COMPLETE  
1 attention

Configuration hygiene agent

Evidence scope: Redacted configuration template evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

Wildcard CORS policy configured

Observed signal: Redacted owner evidence configures a wildcard CORS origin. No source excerpt is retained in the report.

| Why it matters                                                                                   | Required change                                                                                                                                          | Acceptance check                                                                                                      |
|--------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| A wildcard cross-origin policy can expose browser-readable responses more broadly than intended. | Replace the wildcard with an explicit allowlist of trusted origins and keep credentialed requests disabled unless a reviewed product flow requires them. | Add tests that allow each approved origin and reject an unapproved origin, including credentialed preflight behavior. |

OWASP ASVS v5.0.0 — Secure Coding

Dependency agent

Evidence scope: Manifest and lockfile evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

### Unbounded dependency version range

**Observed signal:** Redacted owner evidence contains a latest, wildcard, or early 0.x dependency range. No source excerpt is retained in the report.

|                                                                                                                        |                                                                                                                                                             |                                                                                                                                               |
|------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Why it matters</p> <p>Unbounded or early-version ranges make dependency changes harder to review and reproduce.</p> | <p>Required change</p> <p>Replace the range with a reviewed stable version, commit the lockfile, and update through a tested dependency-review process.</p> | <p>Acceptance check</p> <p>Add CI validation that requires a lockfile and fails if production dependencies use latest or wildcard ranges.</p> |
|------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|

OWASP ASVS v5.0.0 — Dependency Management

AGENT 12

COMPLETE  
1 attention

Supply-chain agent

Evidence scope: Build, CI and release evidence

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

Privileged or unpinned workflow installation pattern

**Observed signal:** Redacted owner evidence contains pull\_request\_target or a remote installer pipe. No source excerpt is retained in the report.

Why it matters

Privileged pull-request workflows or remote installer pipes can execute unreviewed code in the build environment.

Required change

Replace the privileged trigger with an unprivileged pull-request workflow and pin reviewed actions or installer checksums instead of piping remote content to a shell.

Acceptance check

Add a workflow policy test that rejects pull\_request\_target and curl-pipe-shell patterns in CI configuration.

OWASP ASVS v5.0.0 — Secure Development

# Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 13

COMPLETE  
1 attention

Deployment agent

Evidence scope: Redacted runtime and hosting configuration

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence • attention

Privileged container runtime configured

Observed signal: Redacted owner evidence enables privileged or root container execution. No source excerpt is retained in the report.

Why it matters

Required change

Acceptance check

A privileged or root runtime increases the impact of a service compromise.

Run the service as a dedicated non-root user, remove privileged mode, and drop unnecessary Linux capabilities in the deployment configuration.

Add a deployment policy check that rejects privileged mode, root user, and runAsNonRoot: false.

OWASP ASVS v5.0.0 – Configuration

AGENT 14

COMPLETE  
1 attention

Logging & recovery agent

Evidence scope: Logging and recovery-flow evidence

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

Sensitive field written to logs

**Observed signal:** Redacted owner evidence logs a password, token, secret, or recovery artifact. No source excerpt is retained in the report.

Why it matters

Sensitive values in logs can persist beyond the session and expand who can access them.

Required change

Remove the sensitive field from the log call, replace it with a non-sensitive event identifier, and apply a central redaction policy before log transport.

Acceptance check

Add a logging test that exercises the flow and asserts password, token, secret, and recovery values never appear in captured logs.

OWASP ASVS v5.0.0 – Logging

AGENT 15

COMPLETE  
1 attention

Storage & cryptography agent

Evidence scope: Storage, cryptography and lifecycle evidence

1 concrete evidence-backed attention finding requires remediation.

HIGH

high confidence · attention

Deprecated hash used for a password or secret

**Observed signal:** Redacted owner evidence uses MD5 or SHA-1 in a password or secret-handling context. No source excerpt is retained in the report.

Why it matters

MD5 and SHA-1 are not suitable password-protection primitives and can weaken stored-secret protection.

Required change

Replace the deprecated hash with a maintained password-hashing API such as Argon2id or scrypt, use per-password salts, and migrate existing hashes at successful login.

Acceptance check

Add tests that create and verify a new password hash with the approved algorithm and reject legacy MD5/SHA-1 password hashes.

OWASP ASVS v5.0.0 – Cryptography and Data Protection



## Remediation prompt

This consolidated implementation brief contains the agent evidence and corrective work documented in the previous pages. It preserves the report's defensive limits.

You are improving the security of the authorized web application at <https://3000-iqxivav6b63ryvbciag44g-50ce8d6f.us2.manus.computer/>.

### Scope and evidence:

- This is a defensive remediation task based on a bounded WebScan review.
- Coverage: Verified public response; Transport and response headers; Visible cookie attributes; Sampled HTML asset references; Public technology hints; 5 redacted owner-evidence file(s), processed for this review only
- Limitations: No credentialed testing or authentication bypass attempts; No active exploitation, fuzzing, brute force, or denial-of-service testing; Source review is limited to the selected redacted excerpts supplied by the owner

### Prioritized remediation objectives:

1. HSTS policy [Transport agent; medium]
  - Observed signal: strict-transport-security was not present in the verified response.
  - Required change: Set a reviewed Strict-Transport-Security policy once all subdomains are ready for HTTPS.
  - Acceptance check: Request a representative protected route and confirm the strict-transport-security response header is present with an appropriate policy.
2. Content Security Policy [Browser isolation agent; medium]
  - Observed signal: content-security-policy was not present in the verified response.
  - Required change: Implement a restrictive, tested Content-Security-Policy and progressively remove broad script allowances.
  - Acceptance check: Request a representative protected route and confirm the content-security-policy response header is present with an appropriate policy.
3. Referrer policy [Data privacy agent; low]
  - Observed signal: referrer-policy was not present in the verified response.
  - Required change: Set a reviewed Referrer-Policy such as strict-origin-when-cross-origin, subject to product requirements.
  - Acceptance check: Request a representative protected route and confirm the referrer-policy response header is present with an appropriate policy.
4. MIME sniffing protection [Browser isolation agent; low]
  - Observed signal: x-content-type-options was not present in the verified response.
  - Required change: Set X-Content-Type-Options: nosniff for relevant responses and validate declared MIME types.
  - Acceptance check: Request a representative protected route and confirm the x-content-type-options response header is present with an appropriate policy.
5. Permissions policy [Browser isolation agent; low]
  - Observed signal: permissions-policy was not present in the verified response.
  - Required change: Define a Permissions-Policy that disables browser features not required by the product.
  - Acceptance check: Request a representative protected route and confirm the permissions-policy response header is present with an appropriate policy.
6. Observed cookie hardening is incomplete [Session agent; medium]
  - Observed signal: 1 Set-Cookie response value(s) were observed in the verified response; values are intentionally not retained in the report.
  - Required change: Review each session and sensitive-state cookie; apply Secure, HttpOnly,

and an appropriate SameSite setting where compatible with the authentication flow.

- Acceptance check: Inspect cookies emitted by sign-in, recovery, and sensitive state transitions without exposing their values in logs.

7. Potential HTTP resource reference [Client exposure agent; medium]

- Observed signal: The sampled HTML contains at least one http:// resource reference.
- Required change: Replace HTTP resource references with HTTPS sources and add reporting or enforcement through CSP where appropriate.
- Acceptance check: Review production pages in browser developer tools for mixed-content warnings.

8. JWT signing value is embedded in source [Authentication agent; high]

- Observed signal: Redacted owner evidence contains a JWT signing call with a literal value. No source excerpt is retained in the report.
- Required change: Read the JWT signing value from a server-only secret at startup; reject startup when it is missing and rotate the existing value before release.
- Acceptance check: Add a startup test that fails without the secret and an integration test that accepts tokens signed with the configured replacement value only.

9. Client-supplied privilege value accepted [Authorization agent; high]

- Observed signal: Redacted owner evidence assigns a role or privilege value directly from a request body. No source excerpt is retained in the report.
- Required change: Ignore client-supplied privilege fields for protected actions; derive roles server-side and enforce ownership or tenant checks before the state change.
- Acceptance check: Add tests that submit elevated role fields from an unprivileged client and confirm the protected action is denied.

10. Unsafe dynamic rendering or execution API used [Input safety agent; high]

- Observed signal: Redacted owner evidence uses a dynamic execution or HTML-rendering API. No source excerpt is retained in the report.
- Required change: Remove the unsafe API where possible; otherwise sanitize untrusted HTML with a maintained sanitizer and keep scripts, event attributes, and dangerous URL schemes disallowed.
- Acceptance check: Add rendering tests with script tags, event attributes, and javascript: URLs and confirm none execute or render as active content.

11. Stack trace returned to a client [API & error agent; medium]

- Observed signal: Redacted owner evidence sends an error stack in a response payload. No source excerpt is retained in the report.
- Required change: Replace stack-trace responses with a stable error code and generic message; log diagnostic detail only through the server-side logging policy.
- Acceptance check: Add an error-path test that confirms client responses exclude stack, path, and dependency details.

12. Wildcard CORS policy configured [Configuration hygiene agent; medium]

- Observed signal: Redacted owner evidence configures a wildcard CORS origin. No source excerpt is retained in the report.
- Required change: Replace the wildcard with an explicit allowlist of trusted origins and keep credentialed requests disabled unless a reviewed product flow requires them.
- Acceptance check: Add tests that allow each approved origin and reject an unapproved origin, including credentialed preflight behavior.

13. Unbounded dependency version range [Dependency agent; medium]

- Observed signal: Redacted owner evidence contains a latest, wildcard, or early 0.x dependency range. No source excerpt is retained in the report.
- Required change: Replace the range with a reviewed stable version, commit the lockfile, and update through a tested dependency-review process.
- Acceptance check: Add CI validation that requires a lockfile and fails if production dependencies use latest or wildcard ranges.

14. Privileged or unpinned workflow installation pattern [Supply-chain agent; high]

- Observed signal: Redacted owner evidence contains pull\_request\_target or a remote installer pipe. No source excerpt is retained in the report.
- Required change: Replace the privileged trigger with an unprivileged pull-request workflow and pin reviewed actions or installer checksums instead of piping remote content to a shell.

- Acceptance check: Add a workflow policy test that rejects pull\_request\_target and curl-pipe-shell patterns in CI configuration.
15. Privileged container runtime configured [Deployment agent; high]
- Observed signal: Redacted owner evidence enables privileged or root container execution. No source excerpt is retained in the report.
  - Required change: Run the service as a dedicated non-root user, remove privileged mode, and drop unnecessary Linux capabilities in the deployment configuration.
  - Acceptance check: Add a deployment policy check that rejects privileged mode, root user, and runAsNonRoot: false.
16. Sensitive field written to logs [Logging & recovery agent; high]
- Observed signal: Redacted owner evidence logs a password, token, secret, or recovery artifact. No source excerpt is retained in the report.
  - Required change: Remove the sensitive field from the log call, replace it with a non-sensitive event identifier, and apply a central redaction policy before log transport.
  - Acceptance check: Add a logging test that exercises the flow and asserts password, token, secret, and recovery values never appear in captured logs.
17. Deprecated hash used for a password or secret [Storage & cryptography agent; high]
- Observed signal: Redacted owner evidence uses MD5 or SHA-1 in a password or secret-handling context. No source excerpt is retained in the report.
  - Required change: Replace the deprecated hash with a maintained password-hashing API such as Argon2id or scrypt, use per-password salts, and migrate existing hashes at successful login.
  - Acceptance check: Add tests that create and verify a new password hash with the approved algorithm and reject legacy MD5/SHA-1 password hashes.

#### Implementation constraints:

- Preserve existing product behavior and user flows.
- Do not add tracking, weaken authentication, hardcode secrets, or expose private data in logs.
- Prefer framework-native security controls and server-side enforcement.
- Add or update automated tests for every changed security behavior.
- Validate headers, cookies, error handling, and authorization boundaries where relevant.
- Return a concise change summary, affected files, tests run, and any remaining assumptions.
- Do not include exploit payloads, attack automation, or instructions for bypassing controls.

**Safety constraints retained.** The implementation must not add tracking, weaken authentication, hardcode secrets, expose private data in logs, or include exploit payloads, attack automation, or bypass instructions.